Assignment 2 scenario: unusual activity at Aurora Biotech Labs

*This scenario is fictionalized. No real organization, individual, or incident is implied. It is written for CIS*6530 and is not based on any specific real case.*

Background

Aurora Biotech Labs is a mid-sized biotechnology research firm with roughly 600 employees, headquartered in Ontario, with a research division working on several oncology drug candidates currently in mid-stage clinical trials. Aurora's security team is small: a four-person SOC supported by a managed detection and response (MDR) vendor for after-hours coverage.

Over a three-week period, Aurora's security team and the MDR vendor jointly surfaced the following, in roughly the order discovered (not necessarily the order the events actually occurred):

Evidence

1. **Bulk download, then resignation.** A senior research scientist in the oncology division downloaded an unusually large volume of files (several gigabytes, well above her typical monthly usage) from the restricted clinical-trial data repository over two consecutive evenings. Two days later, she submitted her resignation, citing a better opportunity elsewhere, with a standard two-week notice period.

2. **New remote-access tool, foreign IP range.** Network logs show a remote-access tool not on Aurora's approved software list was installed on a workstation in the same research division roughly ten days before the scientist's bulk download. The tool established outbound connections to IP addresses geolocated overseas, with activity concentrated during business hours in that region (overnight, Eastern time).

3. **Targeted phishing campaign.** Aurora's email security gateway flagged (but, in three cases, did not block in time) a spear-phishing campaign sent to five senior scientists roughly three weeks before the bulk download. The emails impersonated a legitimate academic journal's manuscript-submission portal and requested institutional login credentials. Login telemetry shows one recipient's credentials were used from a previously unseen device two days after the email was opened.

4. **DLP alert on personal cloud storage.** The resigning scientist's workstation triggered a data-loss-prevention alert for uploads to a personal (non-corporate) cloud storage account, timed outside of normal business hours, on the same two evenings as the bulk download in item 1.

5. **No extortion contact or leak-site activity.** As of the time of this report, Aurora has received no ransom demand, no extortion threat, and no mention of Aurora or its data on any known ransomware leak site or dark-web marketplace monitored by its threat intelligence vendor.

6. **C2 infrastructure overlap.** Aurora's threat intelligence vendor matched the SSL certificate used by the remote-access tool's command infrastructure (item 2) to infrastructure previously attributed, with moderate confidence, by a different commercial threat intelligence provider to an advanced persistent threat (APT) group with a documented history of targeting pharmaceutical and biotechnology intellectual property.

7. **Counteroffer from an overseas competitor.** Aurora's HR department confirms the resigning scientist disclosed, during her exit interview, that she had accepted a position with a rival pharmaceutical firm. That firm is headquartered in a country in the same general region as the IP ranges in item 2, though HR has no information suggesting that firm is connected to, or aware of, any of the technical activity described above.

8. **Misconfigured access control.** A routine audit, prompted by this incident, found that the restricted clinical-trial repository's access control list had been misconfigured for approximately six weeks, granting read access to roughly 40 employees across the research division who should only have had access to their own project's data — far more people than the three to five who were supposed to have this level of access.

9. **Content of the downloaded files.** A review of exactly which files were downloaded in item 1 shows a mix: about 60% were drug-candidate formulation and trial-design documents (consistent with the scientist's own legitimate project), and about 40% were manufacturing cost and supply-chain documents for a *different* drug candidate, outside her own project, which the misconfigured ACL (item 8) had made accessible to her.

10. **No other compromised accounts.** A full review of authentication logs across all 600 employees found anomalous access patterns on exactly two accounts: the phished scientist's account from item 3, and the resigning scientist's own account. No other employee's account shows any unusual access, login location, or privilege use.

11. **Sector-wide phishing wave.** Aurora’s information-sharing group (a biotech-sector ISAC) circulated an advisory, roughly one week before item 3’s phishing emails were sent, warning members of a broader wave of similar manuscript-portal phishing emails being sent across the biotech sector regionally, not specifically naming Aurora or any other single target.

Hypotheses to start from (you must add at least one more)

- **H1: State-linked economic espionage.** A state-linked or state-tolerated actor is conducting a deliberate operation to acquire Aurora’s intellectual property for the economic benefit of that state’s pharmaceutical sector, using technical intrusion, a recruited or co-opted insider, or some combination of the two.
- **H2: Independent insider threat.** The resigning scientist, acting on her own initiative and without any state or external actor’s direction, is taking data she believes will be useful or impressive at her new employer, motivated by personal career advantage rather than any broader espionage objective.
- **H3: Financially motivated cybercriminal intrusion.** A cybercriminal group compromised Aurora’s network (via the phishing campaign) with the intent to steal data for double-extortion or resale on criminal marketplaces, unrelated to any specific employee’s resignation, which is coincidental or opportunistically exploited.
- **H4: Benign explanation / false alarm.** The individually unusual-looking signals each have an innocent explanation (a legitimate if policy-violating personal backup habit, a phishing email that was in fact not acted on maliciously, a resignation that is simply a resignation) and do not, together, indicate any actual theft of Aurora’s intellectual property.

Your job is not to decide which single hypothesis is “the plot twist answer.” It is to use the evidence to determine, as honestly as the evidence allows, which hypothesis (or hypotheses) the evidence actually supports best — and to say plainly where the evidence runs out.